

解释和提升基于深度学习的网络安全异常检测应用

原创 韩东岐 网络测量那些事儿 2021-11-14 16:00

今天为大家介绍一篇我们研究团队发表的关于基于深度学习的网络安全异常检测系统中的可解释性研究，题目是 DeepAID: Interpreting and Improving Deep Learning-based Anomaly Detection in Security Applications, 该研究发表在网络安全四大会议之一的 CCS'21 中。该会议将于 2021 年 11 月 15-19 日召开，欢迎大家关注。

背景

随着网络空间环境日益复杂，不同的设备、系统、软件会产生海量异构数据和信息，在巨量多源异构数据进行分析、发现和识别异常对于保障系统的可靠性和安全性是至关重要的。异常检测作为一种长期存在的主动防御安全方案，在网络安全场景中有着广泛的应用、如攻击/入侵检测、系统运维检测、异常行为分析等等。

近年来，基于深度学习的异常检测算法被提出并展现了良好的性能，相较于传统的异常检测算法，其主要优势是可以从更多的数据中更好地学习非线性的复杂特征，并且能处理高维和有关联依赖的复杂数据类型（如时间序列、图结构数据等），满足安全场景中数据量大、多源异构、表示复杂的需求。目前，该方法已被应用在各种网络安全异常应用中，如网络异常检测（NDSS'18）、日志异常检测（CCS'17）、APT 检测（RAID'20）等等。

虽然此类异常检测具备良好的前景，但在实际环境中，由于深度学习决策过程黑盒不透明，可解释性的缺失给深度学习模型在实际网络安全场景的应用和部署带来了极大的障碍。具体而言，安全人员和深度学习模型之间的交互非常困难：1) 一方面，安全人员对于模型产生的结果难以理解，这会导致无法信任模型的检测结果，以及无法在模型产生明显错误时进行调试；2) 另一方面，安全人员无法对模型进行反馈和调整，无法根据专家知识提升模型的性能、也无法改进由于概念漂移等问题导致的性能下降。

因此，本研究以解决上述两方面挑战为目标，提出了一套适用于网络安全场景下异常检测模型的 DeepAID 框架，如图 1 所示，帮助安全人员理解异常检测中的深度学习模型，同时提供模型反馈和提升的方法，旨在促进深度学习方法在实际网络安全场景下的应用。

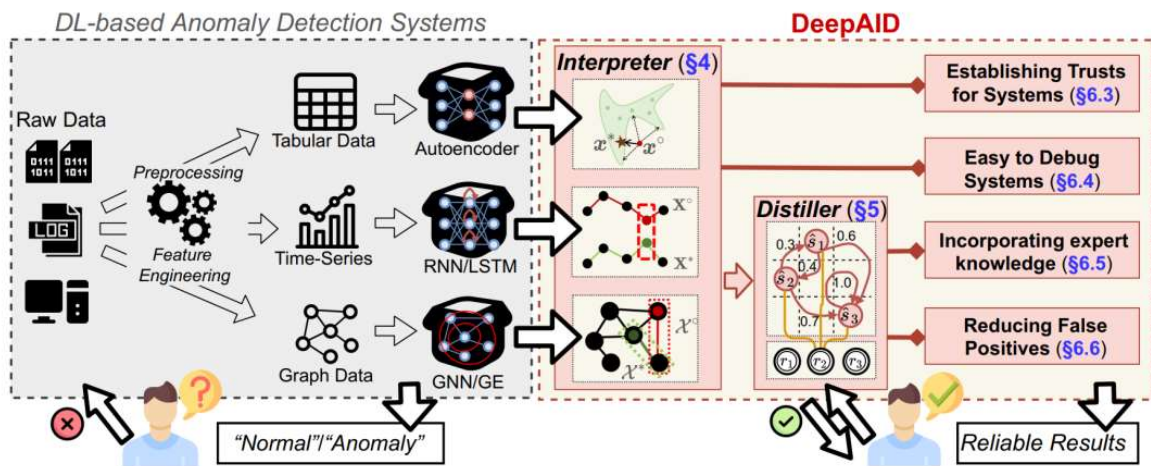


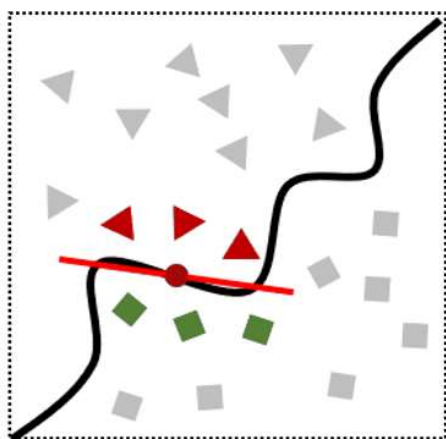
图1 DeepAID总体框架

为什么不使用现有解释方法？

深度学习模型的可解释性在学术界已经被广泛研究，其中一类广泛使用的方法是寻找待解释样本中最重要的部分作为模型的决策依据。然而，我们认为已有的解释方法并不适用于网络安全场景的异常检测系统中，其主要原因有以下两点：

1. 现有解释方法不适用于解释无监督学习模型

目前绝大多数解释方法都应用于监督学习模型（如分类任务）中，然而监督学习和异常检测过程不同：监督学习模型需要多类数据标签进行训练，检测阶段判断和当前样本最接近的类别；而异常检测模型只使用正常数据进行训练，在检测阶段将偏离正常模式的样本判定为异常。因此，两类方法的解释过程也有所不同，不能简单的将监督学习的解释方法迁移到对异常检测模型的解释中。如图2所示，左侧展示的是常见一类基于近似的监督学习解释方法[1][2]，其主要思路是利用待解释点附近的两类数据对复杂模型进行局部近似，训练简单可解释的模型（如线性模型）对待解释点进行解释。然而，对于异常检测而言，我们没有异常的训练数据和异常标签，一种解决思路是额外对异常分布中的数据进行采样来训练替代模型，但这种方法也存在明显问题，因为采样的异常数据实际上并不是原模型的训练数据，使得解释模型无法准确的反映原模型。



监督模型(二分类)解释



异常检测模型解释

图2 监督学习和异常检测的解释研究对比

2. 现有解释方法不适用于网络安全场景

此外，和应用深度学习的人工智能领域不同，安全人员主要关心决策依据、反馈分析和系统提升，解释侧重不同。同时，网络安全领域对错误容忍度低，对解释质量要求高，而已有研究[3]表明，目前绝大多数方法提供的解释结果质量较差，不适用于安全敏感的场景。图3展示了一个简单的例子来解释为什么其他领域的解释方法不适用于安全场景，以图像分类为例（左侧），在解释猫的图片时，不同的解释器（或者同一解释器多次解释）可能会产生多种解释（左下侧），对于人而言，这些解释都是合理的，因为都说明模型捕获到了“猫”的特征。然而，对于安全领域而言（右侧），要分析的数据通常是经过专家知识提取的高维度向量，类似的解释（右下侧）对于安全人员而言则效果较差，一方面，解释结果中包含了太多维度，导致解释可读性差、分析难度和负担过重；另一方面，多次解释同一样本结果的不一致性也会令安全人员困惑于到底哪一部分才是更重要的特征。

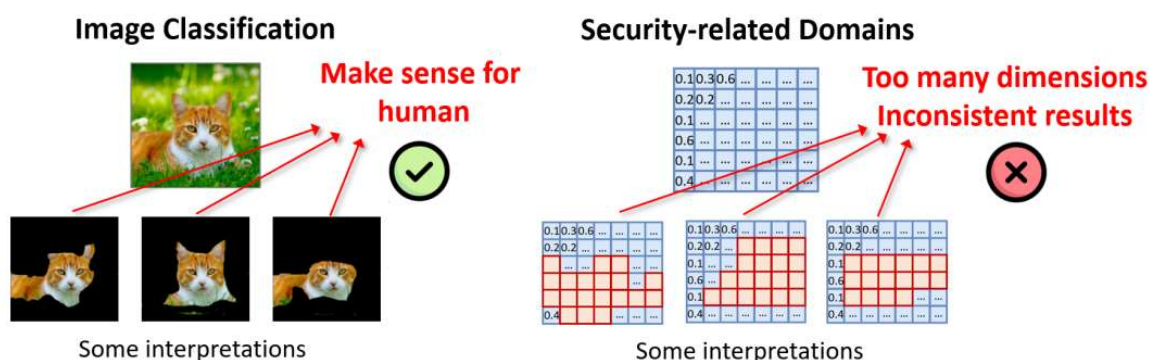


图3 安全和非安全场景下的解释研究对比

综上所述，我们需要提出适用于安全领域的且不依赖于异常数据知识的深度学习解释方法。

模型解释

基于差异的解释：为了提出适合异常检测模型的解释方法，我们还需要回顾图2中所示的监督模型和异常检测的差别。以猫-狗图像分类为例，对于监督学习而言，因为训练过程中同时学习了猫和狗的模式，因此解释一张狗的图片实际上是在寻找当前样本和模型中学习到的狗的数据的“相似性”；相比之下，在异常检测中，如果我们把猫类比为正常，狗类比为异常，因为模型训练阶段没有任何关于狗的信息，所以异常检测的解释过程本质上是在解释当前样本（异常）和模型中猫（正常）模式的“差异性”。因此，我们的解释异常的核心思路是基于差异的解释，即通过首先寻找正常分布中的“参考点”，然后通过对比参考点和异常点之间的差异来解释样本判定为异常的原因。因此，该解释方法的核心是如何寻找一个最合适的参考点，下面将对参考点的选取进行讨论。

寻找最合适的参考点：一种最简单的方法是直接从异常检测的训练集（都是正常数据）中寻找参考点，但这种方法存在着明显问题，依然不能解决图3中所述的安全场景下的问题，比如直接选用训练数据会导致其与异常点之间的差异过大，解释效果差；以及不同的训练集和训练数据会导致解释结果的不稳定/不一致。因此，本研究采用的方法是生成一些能够满足安全场景需求的参考点，我们把寻找参考点的过程转化为在满足一系列约束条件下的优化问题进行求解。如图4所示，为了满足安全场景下的需求，我们提出了参考点求解的五项约束，分别是：

- 1) **保真性 (fidelity) 约束**，即希望解释结果能真实的反映原模型的决策，此部分需要保证求解出的参考点位于原模型正常数据分布之中；
- 2) **稳定性 (stability) 约束**，即希望解释结果对于同一个样本是一致的，此部分的解决方法是在不违背其他约束的前提下让参考点以最短的距离“进入”到模型正常分布之中；
- 3) **简洁性 (conciseness) 约束**，即希望解释结果尽可能简洁、提高可读性，此部分是通过限制参考点和异常点之间差异的维度来实现的；
- 4) **鲁棒性 (robustness) 约束**，即希望解释结果对于随机噪声或者对抗扰动是鲁棒的，此部分的解决方法体现在对参考点的初始化上，我们在异常点周围随机采样进行初始化，实现了一定的平滑效果，并阻碍了攻击者获取到解释器的精确梯度。
- 5) **高效性 (efficiency) 约束**，即希望解释过程尽可能高效，可以应用在一些高速的在线异常检测系统中。

图4 寻找“参考点”需要满足的五项约束

在本研究中，依据上述参考点求解的框架，我们对三类使用不同源数据的异常检测系统（包括表格型、时间序列型和图结构型）提供了解释器的设计和实现（如图1所示），关于优化问题形式化和求解过程的细节，请参考我们的论文，下面将以表格型数据中网络异常检测器 Kitsune (NDSS'18) [4]为例，介绍解释方法的应用案例。

应用案例1：建立对模型的信任

表1中提供了解释器对主机扫描攻击中系统检出异常的解釋结果，其中包含了5个最重要的特征维度及其含义（原始是100维特征），以及各维度下参考点和异常点的取值比较。因为特征都是基于专家知识提取的，所以安全人员很容易从特征值的差异中理解当前异常的含义，比如第一维特征中可看出从单个主机发出的数据包数量高于参考值，第三维特征中可看出发送的都是相似长度的数据包，第五维特征中可看出发送到不同的目的主机，因此安全人员可以理解当前的异常是一种主机扫描的行为，通过查看原始流量进行验证后，就建立了对模型决策的信任。

表1 DeepAID解释器对主机扫描异常的解释结果

应用案例2：对系统错误进行调试 表2中提供了解释器对于某个异常值非常高的误报的解释结果，从解释结果中可以看出，和协方差（cov.）以及相关系数（pcc.）有关的特征的异常值和参考值相差的非常大，通过对原始流量进行验证，我们发现了原系统中关于cov.和pcc.的特征提取存在一定问题，因此我们重新实现了特征提取器并重新对当前数据集进行异常检测，在几乎没有影响正确告警的情况下降低了95%左右的误报。

表2 DeepAID解释器对系统错误数据的解释结果

模型反馈

通过解释器，安全人员已经可以理解模型的结果，但由于模型决策本身还是不透明的，安全人员依然难以和模型进行交互。为了帮助安全人员对模型进行反馈，我们提出了蒸馏器（Distiller）模型。蒸馏器支持专家或安全人员对解释结果提供任何反馈，在异常检测阶段，可以作为原模型和解释器的一个扩展，在提供检测和解释结果的同时还能提供专家对于类似异常的反馈。

简而言之，蒸馏器包含了两个有限自动机（FSM）模型，其中第一个自动机用于存储某个异常的解释结果，第二个自动机用于存储专家对特定解释结果的反馈信息。蒸馏器包含两种工作模型，在更新（update）阶段，专家对于某些异常提供新的反馈，将新的专家知识存储到蒸馏器中，在预测（test）阶段，其作为原模型后端的插件提供相似异常的反馈结果。

图5展示了蒸馏器工作流程的简单例子，其中包含从一个没有任何信息的蒸馏器开始两次更新异常反馈结果并预测的过程，在②中假设专家查看异常的解释后希望将此标注为扫描攻击，则此解释结果（可以看作一个由参考点和异常点差异组成的序列）将会映射到第一个自动机中并更新转移概率矩阵，然后在第二个自动机中添加一个表示扫描攻击的状态，并将刚才解释状态转移到该状态中并更新转移概率矩阵。在③中可以看出蒸馏器已经具备对该异常和相似异常的反馈能力。④和⑤中同理更新了一条专家反馈，其中预测阶段的结果中也可以很好的区分两个不同的反馈。关于蒸馏器具体的理论细节和正确性证明，请参考我们的论文。

图5 DeepAID蒸馏器工作流程示例

实验测评：测试阶段异常反馈的准确性

我们测评了蒸馏器在预测阶段对于已有异常、相似异常和未知异常的反馈能力，即存在多种不同反馈时，蒸馏器是否能够准确的提供异常对应的反馈结果，同时还能保留原模型对于未知异常的检测能力。此部分实验我们将蒸馏器和机器学习多分类器（随机森林和多层感知机）进行对比。机器学习模型和蒸馏器都使用带标注的训练集和测试集，训练集在蒸馏器中可以理解为更新阶段的异常，标签可以理解为专家反馈。结果如表3所示，前两列测评了对训练集中异常的匹配准确度，可以看出随机森林和蒸馏器都可以很好的匹配，中间两列测评了不同方法在测试集上的泛化能力，可以看出蒸馏器的泛化效果（对于类似异常的反馈能力）远好于机器学习模型，最后一列是对于未知异常检测的能力，机器学习模型中类别在训练前已经确定，无法检测未知异常，而蒸馏器可以很好的保留模型对于未知异常的检测能力。

表3 蒸馏器和多分类器异常反馈的准确性对比

总结

在这项研究中，我们提出了首个适用于网络安全异常检测应用的深度学习解释方法，可以为多种不同源数据和模型的异常检测系统提供高保真、可读性强、稳定、鲁棒且高效的解释结果。同时，我们展示了基于解释结果来提升异常检测系统的多种应用案例，包含对模型决策的理解和信任、错误调试，并提出了蒸馏器模型实现专家知识和模型的融合。我们为三类不同异常检测系统提供了解释方法的原型实现。该工作旨在促进深度学习方法在实际网络安全场景下的应用。我们的解释工具已经开源在Github中[5]，欢迎大家关注。

参考文献

[1] Ribeiro et al. "Why Should I Trust You? Explaining the Predictions of Any Classifier". KDD'16

[2] Guo et al. "LEMNA: Explaining Deep Learning based Security Applications". CCS'18

[3] Warnecke et al. "Evaluating Explanation Methods for Deep Learning in Security". EuroS&P'20

[4] Mirsky et al. "Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection". NDSS'18

[5] <https://github.com/dongtsi/DeepAID>

作者简介

韩东岐，1997年生，名草有主，现为清华大学网络科学与网络空间研究院在读博士生，导师为王之梁副教授。主要研究方向为异常检测、流量分析和态势感知。研究成果在CCS、JSAC等重要期刊会议上发表。

 点击蓝字·关注我们 / 开心快乐每一天

阅读 2390 文章已于2021-11-14修改



网络测量那些事儿 关注

分享 收藏 8 21